

04

BOOK 04 / 08

인증·인가·세션

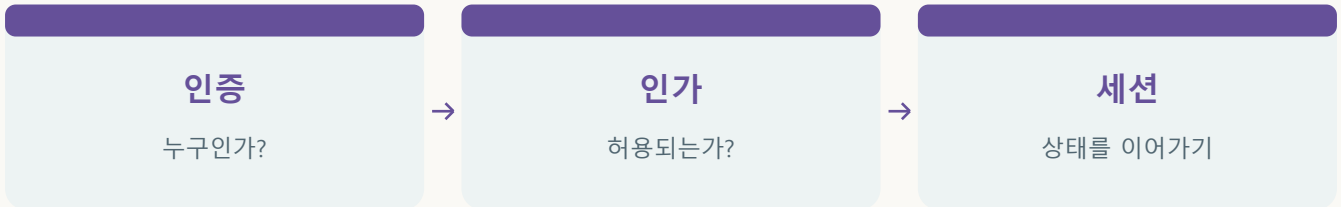
로그인한 사람은 무엇을 할 수 있는가?

개념 이해 / 사례 읽기 / 확인 문제 약 15분

비공개 학습 노트 서비스를 따라 배우는 보안의 기본

이 책을 읽는 방법

신원 확인과 행동 허용은 서로 다른 판단입니다.



읽기 순서

학습 목표와 선수 지식	3
시작 상황: 로그인했으니 볼 수 있을까?	3
개념 설명	3
취약 코드와 개선 코드	3
개발·검수 시 확인사항	4
핵심 요약	4
확인 문제	5
정답과 해설	6
다음 학습과 출처	6

사례를 먼저 읽고, 개념과 코드의 차이를 확인한 뒤 문제를 풀어 보세요. 정답과 해설은 문제 다음 페이지에서 시작합니다.

공통 사례 / 비공개 학습 노트

민서(사용자 101)의 노트는 10번, 준호(202)의 노트는 20번입니다. 모든 노트는 비공개이며, 로그인한 소유자만 조회·수정할 수 있습니다. 제목은 1~80자의 일반 텍스트입니다.

비밀번호·세션 토큰은 로그에 남기지 않고, 권한을 확인할 수 없으면 본문을 보내지 않습니다. 이 가상 서비스의 예제는 학습용 축약본이며 실제 서비스의 계정·데이터·구현과 무관합니다.

학습 목표와 선수 지식

3단원의 요청·응답과 신뢰 경계를 이해했다고 가정합니다. 학습 후에는 인증과 인가를 구분하고, 로그인 상태를 유지하는 수단과 자원별 권한 판단의 관계를 설명할 수 있습니다.

시작 상황: 로그인했으니 볼 수 있을까?

민서는 자신의 계정으로 정상 로그인했습니다. 이 사실은 '민서임을 확인했다'는 의미입니다. 준호의 비공개 노트까지 읽도록 허용했다는 의미는 아닙니다.

개념 설명

개념	확인하는 질문	서비스의 예
인증	누구인지 확인했는가?	로그인 절차로 민서의 신원을 확인
인가	이 대상에 이 행동을 허용하는가?	민서가 20번 노트를 조회할 수 있는지 판단
세션	여러 요청에서 로그인 상태를 어떻게 이어 가는가?	요청의 세션 식별자를 확인해 로그인 사용자를 찾음

이 과정에서는 서버가 로그인 상태를 관리하고 브라우저가 세션 식별자를 쿠키로 보내는 모델을 가정합니다. 쿠키는 브라우저의 값 저장·전송 수단이며 그 자체가 올바른 인증의 증거는 아닙니다. 서버가 유효성, 만료와 해당 사용자를 확인해야 합니다.

세션 식별자를 탈취한 사람이 사용자를 가장할 수 있으므로 보호가 필요합니다. HTTPS 전송, 쿠키의 Secure·HttpOnly·적절한 SameSite 설정, 로그인 시 식별자 갱신과 로그아웃·만료 시 무효화 같은 조치가 관련 됩니다. 각 조치는 역할이 다르며, 쿠키 설정만으로 인가나 CSRF 대응 전체를 대신하지는 않습니다.

취약 코드와 개선 코드

다음 Python 예제는 실행 가능합니다. `current_user_id`는 인증 절차가 이미 확인한 값이라고 가정합니다. 실제 로그인·HTTP·DB 기능은 없습니다.

PYTHON / 실행 예제

```

notes = {
    10: {"owner_id": 101, "body": "민서의 학습 노트"},
    20: {"owner_id": 202, "body": "준호의 학습 노트"},
}

def read_note_vulnerable(current_user_id, note_id):
    if current_user_id is None:
        return None
    note = notes.get(note_id)
    return None if note is None else note["body"]

def read_note_checked(current_user_id, note_id):
    if current_user_id is None:
        return None
    note = notes.get(note_id)
    if note is None or note["owner_id"] != current_user_id:
        return None
    return note["body"]

print(read_note_vulnerable(101, 20)) # 준호의 학습 노트
print(read_note_checked(101, 20))   # None
print(read_note_checked(101, 10))   # 민서의 학습 노트

```

첫 함수는 인증된 사용자 여부만 확인합니다. 두 번째 함수는 노트 소유자와 현재 사용자를 비교합니다. 여기서 `None`은 본문을 반환하지 않는다는 의미이며 HTTP 응답 상태를 정한 것은 아닙니다.

개발·검수 시 확인사항

조회·수정·삭제 각각에서 권한을 확인합니다. 목록 화면에서 숨겼더라도 상세 조회 요청을 직접 보낼 수 있습니다. 노트 번호를 추측하기 어렵게 만드는 것도 소유자 검사를 대신할 수 없습니다.

이 예제는 소유자만 접근하는 정책을 설명합니다. 공유 기능이나 조직별 권한을 도입하면 허용 정책도 다시 설계해야 합니다.

핵심 요약

- 인증 성공은 모든 자원에 대한 인가를 뜻하지 않습니다.
- 세션은 로그인 상태를 이어 주지만 자원별 권한 검사가 별도로 필요합니다.
- 현재 사용자 정보는 요청자가 임의로 보낸 값에서 가져오면 안 됩니다.

확인 문제

1. 로그인 여부만 검사한 뒤 20번 노트를 반환합니다. 민서가 로그인했을 때 빠진 검사는 무엇일까요?

2. 세션 쿠키에 HttpOnly를 설정하면 노트 소유자 검사를 생략할 수 있을까요?

정답과 해설

1. 민서에게 20번 노트 조회를 허용하는지 확인하는 인가 검사입니다.
2. 아닙니다. HttpOnly는 스크립트의 쿠키 접근을 제한하는 속성입니다. 서버의 자원 접근 권한을 판단하지 않습니다.

다음 학습과 출처

인증·인가 구분 및 자원별 검사 원칙: [OWASP Authorization Cheat Sheet](#). 세션 모델과 쿠키 보호: [OWASP Session Management Cheat Sheet](#). 다음에는 입력값의 의미와 사용 위치를 구분합니다.

나의 한 문장

이 강의에서 배운 내용을 동료에게 설명한다면 어떻게 말할까요?
